

Halden Distribution Ltd. — CIS Controls v8.1 IG1 self-assessment report

For: management · **Prepared by:** IT Lead · **Version:** v0.1 (structure) · **Date:** 2026-10-02 **Scope:** all 56 CIS Controls v8.1 Implementation Group 1 safeguards

This is the report structure with the status column deliberately empty. Halden is a fictional 85-user company used for a home-lab portfolio. The assessment has not been run, so ****no** safeguard has a score******. The purpose of this document is to show exactly how the assessment will be filled, what evidence each safeguard will cite, and what "done" looks like — not to present results that do not exist yet.

1. Why assess against CIS IG1

CIS describes **IG1 (56 safeguards)** as essential cyber hygiene and an emerging minimum standard for all enterprises, aimed at small and medium businesses with limited IT and security expertise (docs/plan/00-research-and-selection.md). It is the correct baseline for an 85-user company with one IT generalist: large enough to cover the real risks, small enough to assess honestly. Insurers and customer supplier questionnaires increasingly expect exactly this kind of documented, measured control set.

2. Method

Scale (from the P10 plan):

Score	Meaning
0	Not implemented
1	Partially implemented
2	Implemented on some systems
3	Fully implemented and evidenced

Before vs after: "before" is the inherited Halden state recorded in each project's problem statement. "After" is the state today, counting only what has a file to prove it.

The evidence rule: a score of 3 requires a named evidence source, and if that source is given as a repository path it must resolve to a real file. The assessment tool (projects/p10-governance/scripts/cis_assessment.py) refuses a 3 with no evidence, refuses a 3 whose evidence file does not exist, and refuses any value outside 0–3. A safeguard with no evidence stays blank rather than being scored generously.

Who scores: the IT Lead scores, and each safeguard's evidence is a sanitized artifact from P1–P9. The % implemented is reported as the sum of scores divided by (3 × the number of safeguards scored).

3. Headline result

Metric	Value
Safeguards in scope	56
Safeguards scored (after)	0
Safeguards scored (before)	0
% implemented, before	not measured
% implemented, after	not measured

The percentage is withheld on purpose. When the assessment is run, this table is filled from `projects/p10-governance/reports/cis-ig1-assessment-<date>.md`, whose numbers come straight out of the scored workbook. The companion chart `docs/diagrams/p10-cis-ig1-chart-template.svg` is a labelled **empty template** for the same reason.

4. What the assessment will show, control by control

The column "expected evidence" is how Halden intends to evidence each safeguard, naming the project that produces it. "Status" stays empty until the assessment runs.

Control	Safeguards	Expected evidence comes from	Status
1 Inventory and Control of Enterprise Assets	1.1–1.2	P9 GLPI inventory, reconciled against a network scan and DHCP/AD computer objects	
2 Inventory and Control of Software Assets	2.1–2.3	P9 software inventory; P4 Windows 11 readiness report for unsupported software	
3 Data Protection	3.1–3.6	P10 policy pack (data management, retention, disposal); P1 AGDLP permission matrix + ACL audit; P4 BitLocker escrow	
4 Secure Configuration of Enterprise Assets and Software	4.1–4.7	P1 GPO baseline + as-built; P4 endpoint baseline; P6 firewall rules; P3 LAPS	
5 Account Management	5.1–5.4	P2 account inventory, dormant-account report, quarterly review; P1 password policy; P3 privileged-access tiering	
6 Access Control Management	6.1–6.5	P1 join runbook + P2 JML automation; P2 MFA coverage; P6 VPN MFA; P3 admin MFA	
7 Continuous Vulnerability Management	7.1–7.4	P10 policy pack; P3 remediation rules; P5 WSUS patch compliance and vulnerability dashboard	
8 Audit Log Management	8.1–8.3	P10 policy pack; P7 Wazuh log collection and retention	
9 Email and Web Browser Protections	9.1–9.2	P4 supported-browser baseline; P6 DNS filtering	
10 Malware Defenses	10.1–10.3	P4 Defender status, signature updates, autorun disabled	
11 Data Recovery	11.1–11.4	P8 backup/DR design, restore-test history, immutability proof	

Control	Safeguards	Expected evidence comes from	Status
12 Network Infrastructure Management	12.1	P5 firmware patching record; P6 network standard	
14 Security Awareness and Skills Training	14.1–14.8	Expected gap: no awareness programme exists yet. Roadmap items; a training register will be created	
15 Service Provider Management	15.1	P9 vendor and licence register	
17 Incident Response Management	17.1–17.3	P7 incident roles, contact list, reporting process, tabletop report	

(Controls 13, 16 and 18 contain no IG1 safeguards and are therefore absent by design.)

5. How this report will be completed

1. Run `python3 scripts/evidence_index.py` to see which expected evidence artifacts exist.
2. Score each safeguard in `data/cis-ig1-safeguards.csv`, writing `evidence_source` for any 3.
3. Run `python3 scripts/cis_assessment.py --open-errors` — the tool refuses a 3 with no evidence.
4. Paste the generated headline table into §3 and the per-control table into §4 above.
5. Fill the chart from the per-control scores.
6. Every safeguard still below 3 becomes a risk-register entry (business owner) or a 90-day roadmap item, with the reason recorded.

6. Acknowledgement of the empty state

- **Safeguards scored:** 0 of 56.
- **Charts published with values:** none — the chart is an empty, labelled template.
- **Claims made:** none about the security posture. The honest statement today is "built, not yet measured", and this document says exactly that.